مقيد

شركة القيروان لنظم المعلومات

إجراءات حماية البيانات

وثيقة إجرائية · وثيقة تنفيذية لسياسة حماية البيانات QIS-POL-001

رقم الوثيقة	**QIS-PRC-001**
الإصدار	٠٫٣ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

معلومات الوثيقة

اسم الوثيقة	إجراءات حماية البيانات
رمز الوثيقة	QIS-PRC-001
السياسة الأم	سياسة حماية البيانات — QIS-POL-001 (الإصدار ٠٫٤)
مالك الوثيقة	قائد الحوكمة والمخاطر والالتزام — نايف السالم
مُعِدّ الوثيقة	نايف السالم — قائد الحوكمة والمخاطر والالتزام
إصدار الوثيقة	٠٫٣ (مسودة)

إشارة المشاركة (Traffic Light Protocol)

صُنّفت هذه الوثيقة وفق بروتوكول الإشارة الضوئية (TLP) المعتمد في وثائق الهيئة الوطنية للأمن السيبراني عند المستوى **برتقالي (TLP:AMBER)**، ولا يجوز تداولها خارج هذا النطاق دون موافقة مالك الوثيقة.

● **أحمر** TLP:RED	شخصي وسري للمستلم فقط: لا يجوز للمستلم مشاركتها مع أي فرد من داخل الجهة أو خارجها خارج النطاق المحدد للاستلام.
● **برتقالي** TLP:AMBER	**مشاركة محدودة: يجوز للمستلم مشاركتها داخل جهته مع الأشخاص المعنيين فقط، ومن يتطلب الأمر منهم اتخاذ إجراء بشأنها.** — المستوى المعتمد لهذه الوثيقة
● **أخضر** TLP:GREEN	مشاركة في نفس المجتمع: يجوز مشاركتها مع الجهة نفسها أو جهة ذات علاقة أو في القطاع نفسه، دون تبادلها أو نشرها عبر القنوات العامة.
● **أبيض** TLP:WHITE	غير محدود.

سجل التعديلات

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠٫١	١٠ نوفمبر ٢٠٢٦م	نايف السالم	الإصدار الأول: خمسة إجراءات تنفذ بنود سياسة حماية البيانات، منها إجراءا العقود ووصول الأطراف الخارجية ومشاركة البيانات.
٠٫٢	١٠ نوفمبر ٢٠٢٦م	نايف السالم	تحديث الإحالات إلى المكون الفرعي ٢-٧ وفق الإصدار ٢٠٢٤ من الضوابط الأساسية للأمن السيبراني.

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠٫٣	١١ نوفمبر ٢٠٢٦م	نايف السالم	اعتماد الأرقام الهندية في جميع أرقام الوثيقة، وكتابة أرقام الضوابط بالترتيب المتبع في وثائق الهيئة الوطنية للأمن السيبراني، تيسيراً للبحث عنها في نصوص الهيئة. وتحديث الإحالة إلى الإصدار ٠٫٤ من السياسة QIS-POL-001.

مقيد

اعتماد الوثيقة

الدور	المسمى الوظيفي	الاسم	التاريخ	التوقيع
المالك	قائد الحوكمة والمخاطر والالتزام	نايف السالم	—	—
المُراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	—	—
المُراجِع	الرئيس التنفيذي للمالية (العقود والموارد البشرية)	ماجد القحطاني	—	—
المعتمِد	رئيس اللجنة الإشرافية للأمن السيبراني	فيصل الحربي	—	—

جدول المراجعة

معدل المراجعة	تاريخ آخر مراجعة	تاريخ المراجعة القادمة
مع كل تحديث للسياسة الأم، وسنوياً على الأقل	—	نوفمبر ٢٠٢٧م

مقيد

تصنيف الوثيقة

سري للغاية	تُصنّف الوثيقة «سري للغاية» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم لا يمكن تداركه أو إصلاحه.
سري	تُصنّف الوثيقة «سري» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم، وينطبق على المعلومات الحساسة التي تحدد طريقة عمل الشركة.
مقيد	**تُصنّف الوثيقة «مقيد» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر محدود، وينطبق على المعلومات التي لم تُعتمد للتداول العام خارج الشركة.**
عام	تُصنّف الوثيقة «عام» عندما لا يترتب على الوصول غير المصرح به إليها أو الإفصاح عن محتواها أي أثر على الشركة، وينطبق على الوثائق المعتمدة للنشر العام.

سرية الوثيقة

تعد هذه الوثيقة إحدى وثائق شركة القيروان لنظم المعلومات المصنفة «مقيد»، ويقتصر تداولها على منسوبي الشركة والجهات الحكومية المتعاقدة معها التي تحتاج إلى الاطلاع عليها، ولا يحق نشرها أو تعديلها أو نشر جزء منها لغير المصرح لهم إلا بموافقة كتابية مسبقة من مالك الوثيقة.

جدول المحتويات

١. الغرض

٢. النطاق

٣. العلاقة بالسياسة الأم

٤. الأدوار المشاركة في تنفيذ الإجراءات

٥. خريطة الإجراءات

٦. الإجراء الأول: مراجعة واعتماد متطلبات الأمن السيبراني في العقود

٧. الإجراء الثاني: إدارة وصول الأطراف الخارجية ومشاركة البيانات

٨. الإجراء الثالث: تصنيف البيانات والتعامل معها

٩. الإجراء الرابع: الاستجابة لتسرب البيانات وطلبات أصحاب البيانات

١٠. الإجراء الخامس: الحفظ والإعادة والإتلاف الآمن

١١. متطلبات تمكين وتنفيذ الإجراءات

١٢. مؤشرات قياس الالتزام

١٣. المراجع

مقيد

١. الغرض

تحدد هذه الوثيقة الخطوات التنفيذية التي تترجم بنود سياسة حماية البيانات إلى ممارسات عمل يومية قابلة للقياس والتدقيق، بما يشمل مالك كل خطوة، والمخرج المطلوب منها، والمدة الزمنية لإنجازها، والسجلات الواجب الاحتفاظ بها.

٢. النطاق

تنطبق هذه الإجراءات على جميع إدارات الشركة وموظفيها والمتعاقدين معها، وعلى جميع العقود والاتفاقيات مع العملاء والأطراف الخارجية، وعلى جميع البيانات التي تملكها الشركة أو تعالجها لعملائها في كامل دورة حياتها.

٣. العلاقة بالسياسة الأم

هذه الوثيقة منبثقة من سياسة حماية البيانات QIS-POL-001، ولا تنشئ التزامات جديدة تتجاوزها، وعند التعارض تُقدَّم أحكام السياسة. ويشير كل إجراء إلى أرقام بنود السياسة التي ينفذها، وتُقرأ التعريفات من السياسة مباشرة دون تكرارها هنا.

٤. الأدوار المشاركة في تنفيذ الإجراءات

الدور	المسؤولية في هذه الإجراءات
قائد الحوكمة والمخاطر والالتزام (مسؤول حماية البيانات الشخصية)	تشغيل هذه الإجراءات، ومراجعة المتطلبات الأمنية في العقود، وإدارة سجلي مشاركة البيانات وأنشطة المعالجة، والتنسيق مع جهات التحكم.
العمليات والهندسة الأمنية	التحقق من نتائج المسح الأمني، ومراقبة منع تسرب البيانات، وقيادة الاستجابة لحوادث التسرب مع مركز العمليات الأمنية المُدار.
الرئيس التنفيذي للتقنية	منح الصلاحيات وإلغاؤها، والتشفير، وفصل البيئات، وتعتيم البيانات، والإتلاف الآمن.
الرئيس التنفيذي للمالية	إدارة العقود والمشتريات، وطلب المسح الأمني للمتعاقدين عبر الموارد البشرية.
رئيس تقديم الخدمات	نقل تعليمات العملاء الموثقة، والحصول على موافقاتهم، وإبلاغهم بالحوادث.
مالك البيانات	تحديد تصنيف البيانات، واعتماد الوصول إليها ومشاركتها. وهو لدى بيانات العملاء العميل نفسه، ويمثله رئيس تقديم الخدمات.

الدور	المسؤولية في هذه الإجراءات
الإدارات الطالبة	تقديم طلبات التعاقد والمشاركة المكتملة، والالتزام بقواعد التعامل مع البيانات.

٥. خريطة الإجراءات

تغطي الإجراءات الخمسة دورة حياة البيانات وعلاقة الشركة بالأطراف الخارجية بالتسلسل التالي:

١ تعاقد	٢ وصول ومشاركة	٣ تصنيف وتعامل	٤ استجابة	٥ إتلاف
متطلبات الأمن السيبراني في العقود	المسح الأمني والصلاحيات وسجل المشاركة	التصنيف والترميز والتعتيم	تسرب البيانات وطلبات أصحابها	الإعادة والإتلاف الآمن

الإجراء	المسمى	رقم البند	بنود السياسة المرتبطة
١	مراجعة واعتماد متطلبات الأمن السيبراني في العقود	٦	QIS-4-1-2 · QIS-4-1-7 · ٣-١-٤ · ٢-١-٤ · ١-١-٤
٢	إدارة وصول الأطراف الخارجية ومشاركة البيانات	٧	QIS-4-1-3 · QIS-4-1-1 إلى QIS-4-1-6 · QIS-4-1-8 إلى QIS-4-1-10
٣	تصنيف البيانات والتعامل معها	٨	٢-٧-٢ · QIS-2-7-1 إلى QIS-2-7-4 · المكون الفرعي ٨-٢
٤	الاستجابة لتسرب البيانات وطلبات أصحاب البيانات	٩	QIS-9.5.1 · QIS-9.3.2 · QIS-9.3.1 · QIS-2-7-5
٥	الحفظ والإعادة والإتلاف الآمن	١٠	QIS-9.1.1 · QIS-4-2-3 · QIS-2-7-6

٦ الإجراء الأول: مراجعة واعتماد متطلبات الأمن السيبراني في العقود

مرجع بنود السياسة: ٤-١-١، ٤-١-٢، ٤-١-٣، QIS-4-1-7، QIS-4-1-2

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
قائد الحوكمة والمخاطر والالتزام	عند كل عقد جديد أو مجدد أو معدل	٦ خطوات	نحو ١٠ أيام عمل

٦٫١ الهدف

ضمان تضمين جميع العقود والاتفاقيات مع العملاء والأطراف الخارجية لمتطلبات الأمن السيبراني وحماية البيانات المعتمدة قبل توقيعها، بما يحمي بيانات الشركة وعملائها ويحقق الالتزام النظامي.

٦٫٢ التكرار والنطاق

- العقود الجديدة أو المجددة أو المعدلة مع الموردين ومقدمي الخدمات والاستشاريين والمتعاقدين.
- عقود العملاء التي تعالج فيها الشركة بياناتهم.
- حدث البداية: استلام طلب إنشاء عقد أو تجديده أو تعديله.
- حدث النهاية: اعتماد العقد بعد تضمين المتطلبات، وأرشفته.

٦٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	استلام طلب التعاقد مع نطاق الخدمة ونوع البيانات المتوقع الوصول إليها.	الإدارة الطالبة · المالية اعتماد: الرئيس التنفيذي للمالية	الحوكمة والمخاطر	**طلب جاهز للمراجعة**	يوم ٠
٢	تحديد متطلبات الأمن السيبراني بحسب نوع الخدمة وتصنيف البيانات، وتقييم مخاطر الطرف الخارجي لخدمات الإسناد والخدمات المُدارة.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	العمليات الأمنية · مالك البيانات	**قائمة المتطلبات وتقييم المخاطر**	٣ أيام عمل

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٣	إدراج المتطلبات في العقد: السرية، والحذف الآمن مع الدليل، والإبلاغ عن الحوادث، والمسح الأمني، وموقع المعالجة داخل المملكة، ومدة الحفظ، واتفاقية مستوى الخدمة.	المالية اعتماد: الرئيس التنفيذي للمالية	الحوكمة والمخاطر	**مسودة عقد محدثة**	٣ أيام عمل
٤	في عقود العملاء: إدراج بنود معالجة البيانات (الغرض، والنطاق، والتعليمات، والاستعانة بأطراف أخرى، والإعادة والإتلاف) بالاتفاق مع العميل.	تقديم الخدمات اعتماد: رئيس تقديم الخدمات	العميل · الحوكمة	**بنود معالجة متفق عليها**	وفق العميل
٥	مراجعة البنود الأمنية للتحقق من توافقها مع السياسة والضوابط، وإصدار الموافقة الأمنية.	الحوكمة والمخاطر اعتماد: قائد الحوكمة والمخاطر والالتزام	المالية	**موافقة أمنية على العقد**	يومان
٦	اعتماد العقد وتوقيعه وأرشفته، وإبلاغ الجهات المعنية، وتسجيله في سجل الأطراف الخارجية.	المالية اعتماد: الرئيس التنفيذي	الحوكمة · الأمن	**عقد نافذ مؤرشف**	يومان

٦٫٤ ضوابط تنفيذية إلزامية

- لا يُوقَّع أي عقد يتضمن وصولاً إلى البيانات دون موافقة أمنية موثقة.
- تُراجع العقود السارية التي تنقصها المتطلبات خلال فترة معالجة تحددها اللجنة الإشرافية.
- لا تُقبل مراكز عمليات للخدمات المُدارة تعمل بالوصول عن بُعد من خارج المملكة.
- لا تستعين الشركة بطرف آخر لمعالجة بيانات عميل دون موافقته الكتابية.

٦٫٥ السجلات الواجب الاحتفاظ بها

طلب التعاقد، قائمة المتطلبات، تقييم مخاطر الطرف الخارجي، الموافقة الأمنية، العقد المعتمد، اتفاقية السرية، سجل الأطراف الخارجية.

٧ الإجراء الثاني: إدارة وصول الأطراف الخارجية ومشاركة البيانات

مرجع بنود السياسة: QIS-4-1-3 ،QIS-4-1-1 إلى QIS-4-1-8، QIS-4-1-6 إلى QIS-4-1-10

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
العمليات والهندسة الأمنية	عند كل طلب وصول أو مشاركة	٧ خطوات	نحو ٥ أيام عمل

٧٫١ الهدف

ضمان إدارة وصول الأطراف الخارجية إلى البيانات ومشاركتها معهم بطريقة آمنة وموثقة، مع تطبيق الضوابط الإضافية للمشاريع ذات الحساسية العالية.

٧٫٢ التكرار والنطاق

- جميع الأطراف الخارجية والمتعاقدين المخولين بالوصول إلى بيانات الشركة أو عملائها أو أنظمتهم.
- المشاريع التي يصنفها العميل بأنها عالية الحساسية.
- حدث البداية: اعتماد العقد وطلب منح صلاحية أو مشاركة بيانات.
- حدث النهاية: إلغاء الصلاحيات واستلام دليل الحذف الآمن وإغلاق سجل المشاركة.

٧٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	التحقق من اعتماد العقد وإجراء المسح الأمني لموظفي الطرف الخارجي قبل منحهم أي صلاحية.	العمليات الأمنية · المالية اعتماد: قائد العمليات الأمنية	مالك البيانات	**نتائج المسح الأمني**	٣ أيام عمل
٢	منح الصلاحيات وفق الحد الأدنى ولمدة محددة، بحسابات فردية وتحقق متعدد العوامل.	التقنية اعتماد: الرئيس التنفيذي للتقنية	مالك النظام	**صلاحيات مفعلة**	يوم واحد
٣	مراجعة طلب المشاركة: المبرر، وإعادة التصنيف إلى أقل مستوى، والتعتيم أو المزج عند الحاجة، وموافقات النقل خارج المملكة إن وُجدت.	مالك البيانات · الحوكمة اعتماد: صاحب الصلاحية	العمليات الأمنية	**موافقة المشاركة**	يومان

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	تنفيذ المشاركة عبر القنوات المعتمدة المشفرة، وتوثيقها في سجل مشاركة البيانات.	التقنية اعتماد: مالك البيانات	الحوكمة	**سجل المشاركة**	يوم واحد
٥	في المشاريع عالية الحساسية: تجهيز الأجهزة المخصصة والقاعة المغلقة وضوابط الدخول والخروج، ومراقبة الالتزام طوال المشروع.	العمليات الأمنية · التقنية اعتماد: اللجنة الإشرافية	العميل · مدير المشروع	**بيئة عمل آمنة معتمدة**	قبل البدء
٦	مراجعة الصلاحيات النشطة للأطراف الخارجية، ومتابعة التزامهم بالإبلاغ عن الحوادث.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	مالكو الأنظمة	**تقرير المراجعة**	ربع سنوي
٧	إنهاء الوصول عند انتهاء الحاجة أو العقد، واستلام دليل الحذف الآمن، وإغلاق سجل المشاركة.	التقنية · الحوكمة اعتماد: الرئيس التنفيذي للتقنية	المالية · مالك البيانات	**إثبات الإلغاء والحذف**	خلال ٢٤ ساعة

٧٫٤ ضوابط تنفيذية إلزامية

- لا تُمنح أي صلاحية قبل اكتمال المسح الأمني وتوقيع اتفاقية السرية.
- يُمنع استخدام الحسابات المشتركة للوصول إلى بيانات العملاء.
- لا تُشارك أي بيانات دون توثيق في سجل المشاركة.
- يُمنع إدخال الأجهزة الإلكترونية إلى القاعة المغلقة أو إخراج الأجهزة ووحدات التخزين والوثائق منها.

٧٫٥ السجلات الواجب الاحتفاظ بها

نتائج المسح الأمني، طلبات الصلاحيات، سجل مشاركة البيانات، موافقات المشاركة والنقل، سجلات الدخول إلى القاعة المغلقة، إثباتات الإلغاء والحذف.

٨ الإجراء الثالث: تصنيف البيانات والتعامل معها

مرجع بنود السياسة: ٢-٧-٢، QIS-2-7-1 إلى QIS-2-7-4، المكون الفرعي ٢-٨

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
الرئيس التنفيذي للتقنية	عند كل نظام أو مجموعة بيانات جديدة / سنوياً	٦ خطوات	نحو ٧ أيام عمل

٨٫١ الهدف

ضمان تصنيف كل مجموعة بيانات وتحديد مالكها قبل تشغيلها، وتطبيق قواعد التخزين والنقل والمشاركة بحسب التصنيف، ومنع استخدام البيانات الشخصية الحقيقية في البيئات غير الإنتاجية.

٨٫٢ التكرار والنطاق

- كل نظام جديد أو مستضاف يحتفظ ببيانات.
- كل مجموعة بيانات جديدة تصل من عميل.
- المراجعة السنوية للتصنيف وعند تغيّر طبيعة البيانات.
- حدث البداية: طلب تشغيل نظام أو استلام بيانات جديدة.
- حدث النهاية: تصنيف موثق مطبقة ضوابطه.

٨٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	حصر البيانات في النظام وتحديد مالكها، وطلب تصنيف العميل لبياناته.	التقنية · تقديم الخدمات اعتماد: مالك البيانات	الحوكمة	**قائمة البيانات ومالكها**	يومان
٢	تحديد مستوى التصنيف وتسجيله في سجل الأصول، وترميز البيانات والوثائق بمستواها.	مالك البيانات اعتماد: مالك البيانات	الحوكمة	**تصنيف موثق**	يومان
٣	تحديث سجل أنشطة المعالجة إن تضمنت البيانات بيانات شخصية.	الحوكمة اعتماد: مسؤول حماية البيانات الشخصية	تقديم الخدمات	**سجل أنشطة محدث**	يوم واحد

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	تطبيق ضوابط التصنيف: التشفير أثناء التخزين والنقل، وموقع الاستضافة، وصلاحيات الوصول.	التقنية اعتماد: الرئيس التنفيذي للتقنية	العمليات الأمنية	**إثبات تطبيق الضوابط**	٣ أيام عمل
٥	تعتيم البيانات أو اصطناعها قبل نسخها إلى بيئات التطوير والاختبار.	التقنية · التطوير اعتماد: الرئيس التنفيذي للتقنية	الحوكمة	**بيانات اختبار مُعتَّمة**	قبل النسخ
٦	التحقق من التطبيق ضمن المراجعة الدورية، وإعادة التصنيف عند تغيّر طبيعة البيانات.	الحوكمة اعتماد: قائد الحوكمة والمخاطر والالتزام	مالكو البيانات	**تقرير المراجعة**	سنوياً

٨,٤ ضوابط تنفيذية إلزامية

- لا يُشغَّل نظام يحتفظ ببيانات «مقيد» أو أعلى قبل توثيق تصنيفها.
- تُشفَّر البيانات أثناء النقل بـ TLS 1.2 أو أحدث دائماً.
- لا تُنسخ بيانات شخصية حقيقية إلى بيئة غير إنتاجية دون موافقة كتابية من جهة التحكم.
- تُحفظ مفاتيح التشفير بمعزل عن البيانات.

٨,٥ السجلات الواجب الاحتفاظ بها

قائمة البيانات ومالكها، سجل التصنيف، سجل أنشطة المعالجة، إثباتات التشفير والاستضافة، موافقات الاستثناء، تقارير المراجعة.

٩ الإجراء الرابع: الاستجابة لتسرب البيانات وطلبات أصحاب البيانات

مرجع بنود السياسة: QIS-2-7-5، QIS-9.3.1، QIS-9.3.2، QIS-9.5.1

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
العمليات والهندسة الأمنية	عند كل تسرب أو طلب	٧ خطوات	إبلاغ العميل خلال ٢٤ ساعة

٩٫١ الهدف

ضمان اكتشاف تسرب البيانات واحتوائه وإبلاغ جهة التحكم في الوقت الذي يمكّنها من الوفاء بمهلة الإبلاغ النظامية، وإحالة طلبات أصحاب البيانات إليها دون تأخير، ضمن خطة الاستجابة للحوادث QIS-IRP-001.

٩٫٢ التكرار والنطاق

- أي تسرب فعلي أو مشتبه به لبيانات الشركة أو عملائها، ومنه تنبيهات منع تسرب البيانات.
- بلاغ من طرف خارجي عن حادثة تمس بيانات شاركتها الشركة.
- أي طلب يصل إلى الشركة من صاحب بيانات.
- حدث البداية: رصد التسرب أو استلام البلاغ أو الطلب.
- حدث النهاية: إغلاق الحادثة أو إحالة الطلب وتوثيقه.

٩٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	رصد الحدث عبر منع تسرب البيانات أو مركز العمليات الأمنية المُدار أو بلاغ، وتسجيله.	العمليات الأمنية اعتماد: قائد العمليات الأمنية	الحوكمة	**سجل الحادثة**	الساعة ٠
٢	تقييم الحادثة: البيانات المتأثرة وتصنيفها وعدد أصحابها والعميل المعني، وتصنيف الخطورة وفق QIS-IRP-001.	قائد الحادثة · الحوكمة اعتماد: قائد الحادثة	التقنية	**تقييم الحادثة**	خلال ٤ ساعات
٣	الاحتواء: إيقاف قناة التسرب، وإلغاء الصلاحيات المتأثرة، وحفظ الأدلة.	العمليات الأمنية · التقنية اعتماد: قائد الحادثة	الطرف الخارجي إن وُجد	**إجراءات الاحتواء**	فوراً

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٤	إبلاغ جهة التحكم المعنية بكل تسرب يمس بيانات شخصية دون انتظار تقدير الضرر، مع ما يلزمها لإبلاغ الهيئة السعودية للبيانات والذكاء الاصطناعي خلال ٧٢ ساعة.	تقديم الخدمات · مسؤول حماية البيانات اعتماد: الرئيس التنفيذي	اللجنة الإشرافية	**إشعار موثق للعميل**	خلال ٢٤ ساعة
٥	معالجة السبب الجذري، وتحديث سجل المخاطر، وعقد جلسة الدروس المستفادة.	العمليات الأمنية · الحوكمة اعتماد: قائد الحادثة	اللجنة الإشرافية	**تقرير الإغلاق**	١٠ أيام عمل
٦	طلبات أصحاب البيانات: تسجيل الطلب وإحالته إلى جهة التحكم دون الرد عليه مباشرة إلا بتعليماتها.	الحوكمة اعتماد: مسؤول حماية البيانات الشخصية	تقديم الخدمات	**إحالة موثقة**	خلال يومي عمل
٧	تنفيذ ما تطلبه جهة التحكم لتلبية الطلب (استخراج أو تصحيح أو إتلاف) وتوثيقه.	التقنية اعتماد: الرئيس التنفيذي للتقنية	الحوكمة	**إثبات التنفيذ**	وفق تعليمات العميل

٩٫٤ ضوابط تنفيذية إلزامية

- تُحفظ الأدلة قبل أي إجراء قد يتلفها.
- يُعامل كل تسرب لبيانات شخصية حادثةً واجبة الإبلاغ إلى جهة التحكم.
- لا تُبلغ الشركة أصحاب البيانات أو الجهات الرسمية مباشرة إلا بتعليمات جهة التحكم أو بنص نظامي.
- تُحفظ سجلات الحوادث والطلبات اثني عشر شهراً على الأقل.

٩٫٥ السجلات الواجب الاحتفاظ بها

سجل الحادثة، تقييمها، سجل الاحتواء والأدلة، إشعار العميل، تقرير الإغلاق، سجل طلبات أصحاب البيانات وإحالاتها.

١٠ الإجراء الخامس: الحفظ والإعادة والإتلاف الآمن

مرجع بنود السياسة: QIS-9.1.1، QIS-4-2-3، QIS-2-7-6

مالك الإجراء	دورية التنفيذ	عدد الخطوات	المدة المرجعية
الرئيس التنفيذي للتقنية	ربع سنوي / عند انتهاء عقد أو استبعاد وسائط	٦ خطوات	نحو ١٠ أيام عمل

١٠٫١ الهدف

ضمان عدم الاحتفاظ بالبيانات أطول من مدتها المحددة، وإعادة بيانات العميل إليه عند انتهاء العقد، وإتلاف البيانات ووسائط التخزين إتلافاً آمناً موثقاً.

١٠٫٢ التكرار والنطاق

- البيانات التي انتهت مدة حفظها.
- بيانات العميل عند انتهاء العقد أو إنهائه.
- وسائط التخزين والأجهزة المستبعدة.
- حدث البداية: انتهاء مدة الحفظ أو العقد، أو قرار استبعاد وسائط.
- حدث النهاية: إصدار شهادة الإتلاف وتحديث السجلات.

١٠٫٣ خطوات الإجراء

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
١	حصر البيانات المنتهية مدتها من سجل أنشطة المعالجة، أو بيانات العميل المنتهي عقده.	الحوكمة اعتماد: مسؤول حماية البيانات الشخصية	التقنية	**قائمة الإتلاف أو الإعادة**	ربع سنوي
٢	الحصول على موافقة مالك البيانات أو تعليمات العميل المكتوبة بالإعادة أو الإتلاف.	تقديم الخدمات اعتماد: مالك البيانات	الحوكمة	**موافقة موثقة**	٥ أيام عمل
٣	إعادة بيانات العميل إليه بصيغة قابلة للاستخدام عبر قناة مشفرة، وتوثيق الاستلام.	التقنية اعتماد: الرئيس التنفيذي للتقنية	تقديم الخدمات	**إثبات الإعادة**	وفق العقد
٤	إتلاف البيانات من بيئات الشركة ومزوّد الخدمات السحابية ونسخها الاحتياطية بطريقة لا تسمح باستعادتها.	التقنية اعتماد: الرئيس التنفيذي للتقنية	العمليات الأمنية	**سجل الإتلاف**	٣ أيام عمل

م	الخطوة	المنفّذ / المعتمِد	يُستشار / يُبلَّغ	المخرج	المدة
٥	إتلاف وسائط التخزين المستبعدة بالمسح الآمن أو الإتلاف المادي، واستلام دليل الإتلاف من المزوّد.	التقنية اعتماد: الرئيس التنفيذي للتقنية	المالية	**دليل إتلاف الوسائط**	عند الاستبعاد
٦	إصدار شهادة الإتلاف للبيانات «مقيد» وما فوقها، وتحديث سجل الأصول وسجل أنشطة المعالجة.	الحوكمة اعتماد: قائد الحوكمة والمخاطر والالتزام	العميل عند الطلب	**شهادة الإتلاف**	يومان

١٠٫٤ ضوابط تنفيذية إلزامية

- لا يُتلف أي سجل خاضع لمدة حفظ نظامية قبل انقضائها، ولا تُتلف أدلة حادثة مفتوحة.
- يشمل الإتلاف النسخ الاحتياطية ونسخ المزوّد، لا البيئة الأساسية وحدها.
- تُصدر شهادة إتلاف لكل عملية إتلاف لبيانات «مقيد» وما فوقها.
- لا تُعاد البيانات إلا عبر قناة مشفرة معتمدة.

١٠٫٥ السجلات الواجب الاحتفاظ بها

قوائم الإتلاف والإعادة، موافقات المالك والعميل، إثباتات الإعادة، سجلات الإتلاف، أدلة إتلاف الوسائط، شهادات الإتلاف.

١١. متطلبات تمكين وتنفيذ الإجراءات

١١٫١ الأنظمة والأدوات المطلوبة

الأداة / النظام	الغرض	الإجراءات
سجل الأطراف الخارجية والعقود	تتبع العقود ومتطلباتها الأمنية والمسح الأمني	١، ٢
سجل مشاركة البيانات	توثيق كل عملية مشاركة وموافقاتها وإغلاقها	٢
سجل الأصول وسجل أنشطة المعالجة	التصنيف والمالك ومدد الحفظ	٣، ٥
أدوات منع تسرب البيانات	رصد خروج البيانات الحساسة عبر البريد والتخزين السحابي والأجهزة	٤
خزنة المفاتيح وأدوات التعتيم	إدارة مفاتيح التشفير وتعتيم بيانات الاختبار	٣
أدوات المسح الآمن	إتلاف البيانات ووسائط التخزين	٥

١١٫٢ مصفوفة الموافقات

القرار	المعتمِد
الموافقة الأمنية على عقد	قائد الحوكمة والمخاطر والالتزام
توقيع عقد يتضمن وصولاً إلى بيانات العملاء	الرئيس التنفيذي
مشاركة بيانات «مقيد» أو أعلى مع طرف خارجي	مالك البيانات، وجهة التحكم في بيانات العملاء
نقل بيانات خارج المملكة	جهة التحكم كتابياً، مع صاحب الصلاحية في الشركة
استخدام بيانات حقيقية في بيئة غير إنتاجية	جهة التحكم كتابياً، مع قائد الحوكمة والمخاطر والالتزام
اعتماد بيئة مشروع عالي الحساسية	اللجنة الإشرافية للأمن السيبراني

١٢. مؤشرات قياس الالتزام

الرمز	المؤشر	المستهدف	الإجراء
PRC-01	نسبة العقود التي صدرت لها موافقة أمنية قبل توقيعها	١٠٠٪	١
PRC-02	نسبة الصلاحيات الممنوحة لأطراف خارجية بعد اكتمال المسح الأمني	١٠٠٪	٢
PRC-03	نسبة الأنظمة الجديدة المصنفة بياناتها قبل التشغيل	١٠٠٪	٣
PRC-04	نسبة حوادث تسرب البيانات المبلغ بها العميل خلال ٢٤ ساعة	١٠٠٪	٤
PRC-05	نسبة عمليات الإتلاف الموثقة بشهادة إتلاف	١٠٠٪	٥

١٣. المراجع

النوع	رمز المرجع	اسم المرجع
داخلي	QIS-POL-001	سياسة حماية البيانات (السياسة الأم)
داخلي	QIS-IRP-001	خطة الاستجابة للحوادث السيبرانية
داخلي	QIS-RR-001	سجل المخاطر
داخلي	QIS-PRF-001	ملف الشركة ونطاق البرنامج
خارجي	ECC-2:2024	الضوابط الأساسية للأمن السيبراني — الهيئة الوطنية للأمن السيبراني
خارجي	DCC-1:2022	ضوابط الأمن السيبراني للبيانات — الهيئة الوطنية للأمن السيبراني
خارجي	PDPL	نظام حماية البيانات الشخصية ولائحته التنفيذية